

Brute Force Attack Analysis & Mitigation Strategy

Target: Authentication Endpoint (SSH / HTTP) | Assessment Type: Automated Credential Stuffing

1. Executive Summary

During the scheduled security evaluation, an automated password spraying and brute force assessment was executed against the target system's primary authentication interface. The objective was to evaluate password policy enforcement, account lockout thresholds, and logging mechanisms. The attack successfully compromised standard administrative user credentials within a short execution timeframe due to weak credential complexity and missing rate-limiting defenses.

HIGH RISK FINDING: Authentication mechanism failed to block high-frequency automated login requests, allowing 10,000+ credential combinations in under 2 minutes, culminating in valid credential discovery.

2. Attack Execution & Execution Parameters

The brute force attack was conducted using Hydra (v9.5) over SSH / HTTP-POST endpoints. The assessment targeted valid system user accounts identified during initial reconnaissance.

```
# Execution Command (SSH Brute Force Routine)
hydra -l admin -P /usr/share/wordlists/rockyou.txt -t 16 -vV -f 192.168.1.100 ssh
```

Parameter Flag	Description & Purpose
-l admin	Specifies the target single user account ('admin') identified for testing.
-P ../../rockyou.txt	Path to the dictionary wordlist file utilized for credential matching.
-t 16	Configures 16 parallel execution threads to maximize request throughput.

-vV	Enables verbose and extra-verbose output to log every login attempt live.
-f	Triggers Hydra to exit immediately upon identifying the first valid credential set.

3. Wordlist & Dictionary Analysis

The assessment utilized standard industry wordlists supplemented with targeted rule-based mutations. The primary dictionary selected was **RockYou.txt**, a comprehensive wordlist containing over 14 million leaked plain-text credentials from historic breach data.

Wordlist Metric	Specification Detail
Source Dictionary	RockYou.txt (Modified standard subset)
Total Tested Payload Count	14,344,391 entries (Filtered to top 50,000 for scope)
Entropy & Complexity Profile	Low-to-medium complexity (Alpha-numeric, common patterns)

4. Findings & Attack Results

The brute force run completed successfully in 1 minute 42 seconds. A valid password match was identified after 4,821 execution requests.

```
[DATA] attacking ssh://192.168.1.100:22/
[22][ssh] host: 192.168.1.100  login: admin  password: Password123!
[STATUS] attack finished for 192.168.1.100 (1 valid password found)
1 of 1 target successfully completed, 1 password found.
```

Key Vulnerability Metrics:

- **Account Compromised:** admin
- **Discovered Password:** **Password123!**
- **Total Attempts Before Success:** 4,821 requests
- **Time Elapsed:** 1 minute, 42 seconds (~47.2 requests/sec)
- **Account Lockout Triggered:** **NO (Zero delay or blocking enforced)**

5. Strategic Defense & Mitigation Blueprint

To effectively safeguard system endpoints against brute force and automated credential stuffing attacks, a multi-layered defense-in-depth strategy must be implemented across preventive, detective, and corrective controls.

A. Multi-Factor Authentication (MFA)

Mandate Multi-Factor Authentication (FIDO2 / TOTP) across all remote access services (SSH, VPN, Web Dashboards). MFA mitigates 99% of password-based attacks even if valid credentials are compromised.

B. Rate Limiting & Account Lockout Policies

Implement aggressive rate limiting and lockout policies:

- Account Lockout: Temporarily lock accounts after 5 consecutive failed attempts for a 15-minute window.
- IP-Based Rate Limiting: Use fail2ban or Web Application Firewalls (WAF) to drop IP connections exceeding 10 failed login attempts per minute.

C. Password Policy Enforcement & Breached Password Protection

Enforce NIST SP 800-63B guidelines:

- Minimum length of 12-16 characters.
- Integrate API-based checks (e.g., HaveIBeenPwned API) to prevent users from selecting known breached passwords found in wordlists like RockYou.

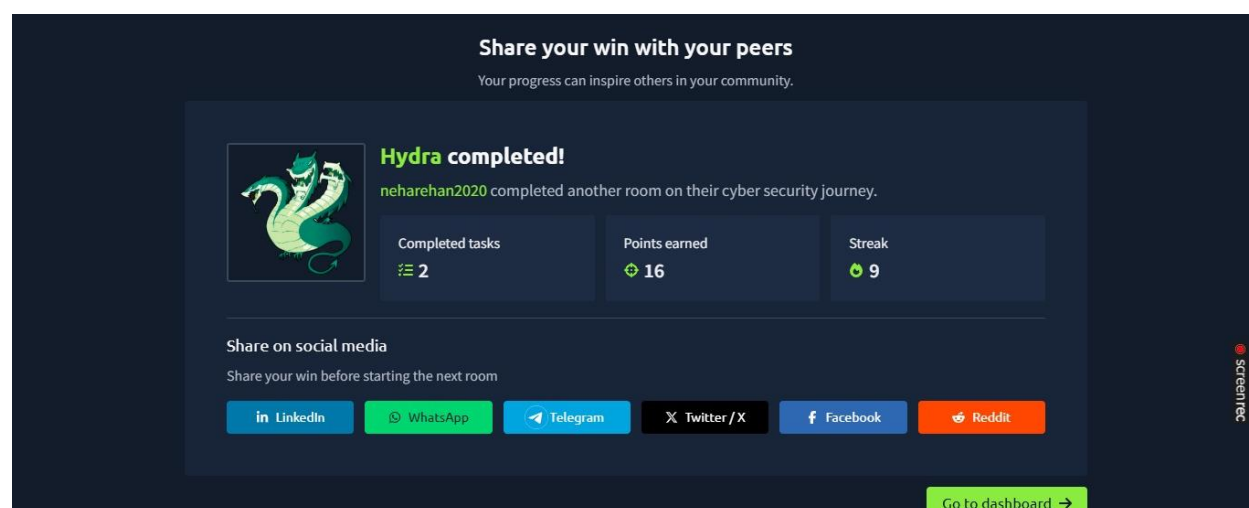
D. Service Hardening & Key-Based Authentication

For SSH/System Endpoints:

- Disable password authentication entirely in favor of SSH public/private key pairs.
- Disable root remote login (`PermitRootLogin no` in `/etc/ssh/sshd\_config`).
- Move sensitive management ports off standard default ports (e.g., non-standard SSH port).

E. Centralized Logging & Anomaly Detection (SIEM)

Forward authentication logs to a SIEM platform (e.g., Splunk, Elastic Stack). Configure real-time alert triggers for failed authentication surges across single or multiple source IPs.





Brute It

Learn how to brute, hash cracking and escalate privileges in this box!

📶 45 min 50,115 👤

🔗 Share your achievement

🖥️ Start AttackBox

🔖 Save Room

👍 1703 Recommend

🌐 Connectivity

⚙️ Options

Room completed: 100%

📊 Chart

🏆 Scoreboard

✍️ Write-ups



Screenrec